Experiment No. 7

Perform Web Application Reconnaissance Using Various Tools

AIM

To gather information about a target web application's architecture, technologies, input points, and attack surface using reconnaissance tools such as Burp Suite, OWASP ZAP, and WhatWeb.

PROCEDURE

1. Launch the target web application in a browser configured to proxy traffic through Burp Suite / OWASP ZAP.
2. Browse through all visible pages, forms, and links of the application while the proxy tool passively records every request in its site map.
3. Use WhatWeb / Wappalyzer to identify the front-end framework, back-end language, CMS, and third-party libraries used by the application.
4. Identify all input fields, forms, and parameters (GET/POST) captured in the proxy history that could act as attack surface.
5. Use Burp Suite's 'Target > Site map' feature to visualize the application's structure and identify hidden or unlinked endpoints.
6. Check response headers and cookies for security attributes (HttpOnly, Secure, SameSite) and note any missing protections.
7. Compile the application's technology stack, page structure, and identified parameters into a reconnaissance report.

SAMPLE OUTPUT

```
Burp Suite Site Map for testapp.local:
  /index.php           [GET]
  /login.php           [GET, POST] params: username, password
  /search.php          [GET]       params: query
  /profile.php?id=     [GET]       params: id
  /upload.php          [POST]      params: file

Wappalyzer detection:
  Framework: CodeIgniter 3.1    Web Server: Apache 2.4
  JS Library: jQuery 3.5.1      Database (inferred): MySQL

Cookie analysis: session cookie missing 'HttpOnly' and 'Secure' flags.
```

RESULT

Web application reconnaissance was successfully performed, mapping the application's structure, identifying input parameters and technologies in use, and noting a cookie security misconfiguration, which together define the application's attack surface.